

THREAT INTELLIGENCE REPORT

ShinyHunters / UNC6040 / UNC6240 Activity Overview

Prepared for: Internal Security Review

Prepared by: #####

Date: May 2026

Executive Summary

ShinyHunters is a financially motivated cybercriminal group engaged in large-scale data theft, extortion, and collaboration with other threat actors. Their operations overlap with activity clusters tracked as UNC6040 (initial access) and UNC6240 (extortion). Evidence also suggests operational ties to ScatteredSpider (UNC3944), known for sophisticated social-engineering and cloud-identity compromise.

This report analyzes ShinyHunters' extortion infrastructure, hosting environment, operational TTPs, and a case study involving OAuth-based cloud compromise. It also highlights the group's use of bulletproof hosting and public leak sites to pressure victims.

1. Threat Actor Overview

1.1 ShinyHunters

ShinyHunters is a well-established cybercriminal group active since 2020, specializing in data breaches, credential theft, and extortion. They frequently publish stolen data on common leak sites and platforms

1.2 Associated Activity Clusters

UNC6040 - Initial access, vishing, identity compromise, OAuth abuse

UNC240 - Extortion, data theft, leak site

ScatteredSpider - Social engineering, SIM swapping, Cloud identity attacks

These clusters share tooling, infrastructure, and operational patterns.

2. Extortion Infrastructure

2.1 Public Leak Site

URL: `http://91.215.85.103/pay_or_leak`

This server hosts ShinyHunters' extortion portal, listing victims who refused to pay ransom. The site includes:

- Partial data leaks
- Chat logs from ransom negotiations
- Threats and pressure tactics
- "Examples" intended to coerce future victims

2.2 Known Victims Listed

- Alert360
- Ameriprise
- CarnivalCorp
- Odido
- Vimeo
- Woflow

These align with ShinyHunters' pattern of targeting large organizations with valuable customer data.

3. Hosting Infrastructure Attribution

3.1 Hosting Provider: Prospero OOO

- Website: <https://pro-spero.ru/>
- Marketed as a "bulletproof hosting service"
- ASN: AS200593
- BGP network created: Dec 12, 2022
- Last update: Mar 2, 2026
- Domains hosted: ~12,449
- IPv4 addresses: 768
- IPv6 addresses: 0
- Geolocation: St. Petersburg, Russia

Associated IP Ranges

- 91.202.233.0/24
- 91.215.85.0/24
- 193.24.123.0/24

Routing Notes

Kentik previously observed routing paths involving Kaspersky infrastructure, though Kaspersky denied involvement.

Assessment

Prospero OOO exhibits multiple indicators of bulletproof hosting and has been repeatedly associated with cybercriminal infrastructure. The ShinyHunters leak server fits this pattern, and is proven to be related through various ip lookups.

4. Actor Verification & Communication Channels

4.1 PGP Verification

Official PGP site: <https://shinyhunte.rs>

- Used to authenticate legitimate ShinyHunters leaks and prevent impersonation.

4.2 Darknet Presence

Onion site:

- <http://shnyhntww34phqoa6dcgnvps2yu7dlwzmy5lkvejwjd06z7bmgshzayd.onion/>

4.3 Contact

- Email: shinygroup@onionmail.com

5. Attack Chain Analysis (Case Study: Instructure)

Note: This section reflects observed patterns and my current understanding. Some details remain unconfirmed, and may not all be correct.

5.1 Initial Access

Tactic: Persistence

Technique: OAuth Abuse (MITRE ATT&CK T1671)

Likely Attack Path

1. Vishing call impersonating IT support
2. User tricked into authorizing a malicious OAuth application
3. Attackers elevate OAuth permissions
4. OAuth app becomes a service principal, enabling:
 - MFA bypass
 - Password-independent access
 - Persistence even if the user is disabled

This mirrors UNC6040's known TTPs.

5.2 Data Collection

Tactic: Collection

Technique: T1213.004 – Accessing cloud-stored data via authorized API tokens

Attackers accessed student data stored in cloud repositories using the OAuth app's elevated permissions.

5.3 Timeline Summary

- Initial compromise via OAuth abuse
- Instructure deployed a patch that removed attacker access
- Months later, attackers exploited a new, undisclosed vulnerability
- Student data was exfiltrated and is currently held for ransom
- The new vulnerability has not been publicly identified

Assessment

The attack pattern aligns with UNC6040/UNC6240 behavior, though the second vulnerability remains unverified.

6. MITRE ATT&CK Mapping

Phase	Technique	ID
Initial Access	Social Engineering / Vishing	T1598
Persistence	Malicious OAuth Application	T1671
Privilege Escalation	OAuth Permission Elevation	T1548
Defense Evasion	MFA Bypass via OAuth Tokens	T1550
Collection	Cloud Data Access via API	T1213.004
Exfiltration	Cloud API Exfiltration	T1567
Impact	Data Theft & Extortion	T1657

7. Overall Assessment

ShinyHunters and their associated clusters demonstrate:

- Advanced social-engineering capabilities
- Deep understanding of cloud identity systems
- Effective use of OAuth for long-term persistence
- Reliance on bulletproof hosting for extortion infrastructure
- Public leak sites to pressure victims
- Multi-stage intrusions with cloud-focused TTPs

Their operations remain active and continue to evolve.

8. Recommendations

Identity & Access

- Enforce OAuth app approval workflows
- Monitor for new OAuth apps with high-risk scopes
- Require admin approval for all third-party integrations
- Implement conditional access policies

Monitoring

- Alert on anomalous OAuth token usage
- Monitor API calls from unusual IP ranges
- Track new service principals created outside change windows

Hardening

- Disable unused OAuth grant types
- Restrict API scopes to least privilege
- Conduct regular cloud configuration audits

Incident Response

- Revoke OAuth tokens during account resets
- Review all service principals for unauthorized permissions
- Conduct full cloud-audit log reviews after any suspected compromise